LECTURE 08

Compliance and Governance

Information Security Governance, Risk Management & Regulatory Compliance

Learning Outcomes

1. Explain the relationship between information security governance, risk management and compliance.
2. Describe major compliance requirements using GDPR and HIPAA and explain ENISA’s role.
3. Select and implement appropriate security controls to support compliance objectives.
4. Explain how audits, assessments, evidence collection and compliance reporting are performed.

What is Information Security Governance?

1. Information security governance is the system used to direct, control and oversee an organization’s security activities.

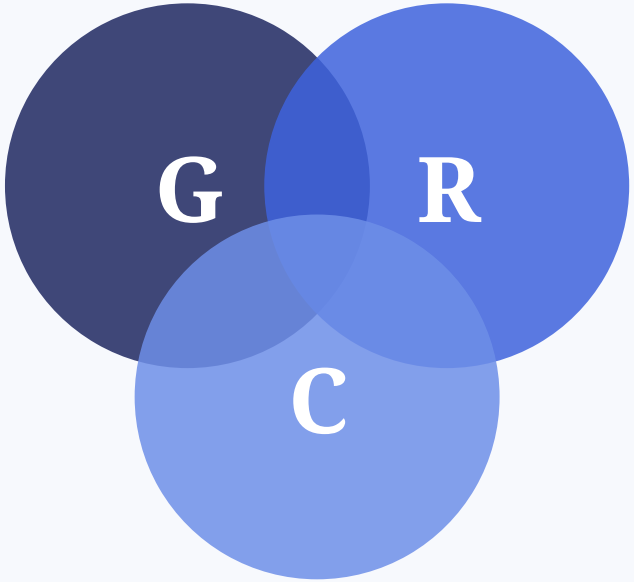
2. It aligns security objectives with business objectives, legal obligations and risk appetite.

3. Governance establishes accountability: who makes decisions, who owns risks and who verifies that controls work.

4. Typical governance mechanisms include policies, standards, procedures, committees, metrics and management reviews.

Governance, Risk and Compliance (GRC)

1. Governance: establishes direction, responsibilities and decision-making structures.
2. Risk management identifies threats and vulnerabilities, evaluates risk and selects appropriate treatments.
3. Compliance: demonstrates that required laws, regulations, contracts, policies and standards are being followed.
4. GRC integrates these activities, so security is managed systematically rather than as isolated technical tasks.



Why Compliance Matters

1. Protects personal, financial, health and other sensitive information.
2. Reduces legal, financial, operational and reputational exposure.
3. Creates minimum expectations for security and privacy practices.
4. Improves accountability through documented controls, evidence and reporting.
5. Supports customer, partner and regulator confidence.

Regulations, Standards and Guidance

1. Regulations/laws: legally enforceable requirements, such as the GDPR.
2. Sector-specific rules: requirements applying to particular industries, such as HIPAA in the U.S. healthcare sector.
3. Standards: structured requirements or best practices, e.g., ISO/IEC 27001.
4. Frameworks: organized approaches for managing cybersecurity, e.g., NIST Cybersecurity Framework.
5. Guidance: recommendations and good practices published by bodies such as ENISA.

GDPR – Overview

1. The General Data Protection Regulation (GDPR) governs the processing of personal data in the European Union/European Economic Area.

2. It applies to organizations established in the EU and can also apply to organizations outside the EU when offering goods/services to, or monitoring, people in the EU.

3. It focuses on lawful, fair and transparent processing of personal data.

4. Organizations must apply appropriate technical and organizational measures to protect personal data.

GDPR – Core Data Protection Principles

1. Lawfulness, fairness and transparency.
2. Purpose limitation – collect data for specified and legitimate purposes.
3. Data minimization – collect only what is necessary.
4. Accuracy – keep personal data accurate and up to date.
5. Storage limitation – retain data only as long as necessary.
6. Integrity and confidentiality – protect against unauthorized access, loss or damage.
7. Accountability – be able to demonstrate compliance.

GDPR – Important Requirements

1. Establish a lawful basis for processing personal data.
2. Provide clear privacy information to individuals.
3. Support data subject rights such as access, rectification and erasure where applicable.
4. Apply data protection by design and by default.
5. Maintain appropriate records and security measures.
6. Certain personal-data breaches must be notified to the supervisory authority within 72 hours of becoming aware, where required by Article 33.

HIPAA – Overview

1. HIPAA is a U.S. federal law relevant to protected health information (PHI).
2. It applies primarily to covered entities and certain business associates.
3. The Privacy Rule addresses permitted uses/disclosures and individual rights relating to PHI.
4. The Security Rule establishes safeguards for electronic protected health information (ePHI).
5. The Breach Notification Rule establishes notification requirements for certain breaches of unsecured PHI.

HIPAA Security Safeguards

Administrative Safeguards

- Security management process and risk analysis
- Assigned security responsibility
- Workforce security and training
- Contingency planning and evaluation

Physical & Technical Safeguards

- Facility and workstation access controls
- Device and media controls
- Access control for ePHI
- Audit controls, integrity and transmission security

ENISA – Role in Cybersecurity

1. ENISA is the European Union Agency for Cybersecurity.
2. ENISA is not a regulation like GDPR; it supports EU cybersecurity policy and implementation.
3. It publishes cybersecurity guidance, good practices, threat landscape reports and implementation resources.
4. It supports Member States, EU institutions and organizations in strengthening cybersecurity capabilities.
5. ENISA material can help organizations interpret risks and select security practices alongside applicable legal requirements.

GDPR, HIPAA and ENISA – Comparison

Aspect	GDPR	HIPAA	ENISA
Nature	EU data-protection regulation	U.S. federal health-information law	EU cybersecurity agency
Primary focus	Protection of personal data	Protection and permitted use of PHI/ePHI	Cybersecurity guidance, support and good practices
Typical organizational response	Privacy governance + technical/organizational measures	Privacy/security safeguards + documentation	Use guidance to strengthen cybersecurity practices

What is a Security Control?

1. A security control is a safeguard or countermeasure used to reduce security or privacy risk.

2. Controls may address people, processes, technology or the physical environment.

3. Compliance requirements often state what outcome is required; controls provide practical mechanisms to achieve that outcome.

4. Controls should be selected based on risk, legal obligations, organizational context and the sensitivity of information.

Security Control Categories

By Implementation

- Administrative: policies, training, risk management, supplier management
- Technical: MFA, encryption, firewalls, logging, endpoint protection
- Physical: locks, CCTV, secure areas, device protection

By Purpose

- Preventive: stop or reduce incidents before they occur
- Detective: identify suspicious events or control failures
- Corrective: restore systems and address causes after an event
- Compensating: alternative control when the preferred control is not feasible

Access Control and Identity Management

1. Apply least privilege: users receive only the permissions needed for their role.
2. Use role-based or attribute-based access control where appropriate.
3. Require strong authentication and multi-factor authentication for sensitive systems.
4. Perform periodic access reviews and promptly remove unnecessary accounts.
5. Separate privileged administrator accounts from normal user accounts.
6. Maintain authentication and authorization logs as compliance evidence.

Data Protection Controls

1. Encrypt sensitive data in transit using secure communication protocols.
2. Encrypt sensitive stored data where appropriate and protect encryption keys.
3. Classify data according to sensitivity and handling requirements.
4. Use retention and secure disposal rules to avoid unnecessary storage.
5. Apply backups and test restoration procedures.
6. Use data loss prevention, masking, pseudonymization or tokenization where appropriate.

Operational Security Controls

1. Patch and vulnerability management to reduce exposure to known weaknesses.
2. Secure configuration and hardening of operating systems, applications and cloud services.
3. Centralized logging, monitoring and alerting for suspicious activity.
4. Malware protection and endpoint security.
5. Incident response procedures with clearly assigned responsibilities.
6. Security awareness training and phishing/social-engineering education.

Mapping Controls to Compliance Requirements

Requirement / Objective	Example Control	Evidence	Purpose
Restrict unauthorized access	MFA + role-based access	Access lists, authentication logs	Preventive
Protect sensitive data	Encryption	Configuration and key-management records	Preventive
Detect suspicious activity	Centralized logging/SIEM	Alert and log records	Detective
Reduce known vulnerabilities	Patch management	Scan reports and patch records	Preventive/Corrective
Respond to incidents	Incident response plan	Plan, exercise results, incident tickets	Corrective

Compliance in DevSecOps

1. Translate policies and compliance requirements into repeatable development and deployment controls.
2. Use secure coding standards and code review throughout development.
3. Integrate automated security checks into CI/CD pipelines where appropriate.
4. Manage secrets securely instead of storing credentials in source code.
5. Record approvals, test results, changes and deployment evidence.
6. Continuous monitoring helps identify configuration drift and control failures after deployment.

Audits and Compliance Assessments

1. An audit evaluates whether defined requirements and controls are being followed and whether evidence supports compliance claims.

2. Internal audits are performed by or on behalf of the organization to identify weaknesses before external review.

3. External audits or assessments are conducted by independent parties or regulatory/assurance bodies where applicable.

4. A compliance assessment compares current practices against defined requirements and identifies gaps.

Typical Audit Lifecycle

1

Define Scope & Criteria

Systems, locations, processes, standards and period under review.

2

Plan the Audit

Identify stakeholders, evidence requirements and sampling approach.

3

Collect Evidence

Policies, logs, configurations, tickets, reports, interviews and observations.

4

Test Controls

Determine whether controls are designed appropriately and operating as intended.

5

Document Findings

Record gaps, risks, root causes and supporting evidence.

6

Remediate & Follow Up

Assign actions, owners and deadlines, then verify closure.

Audit Evidence and Common Findings

Examples of Audit Evidence

- Policies, standards and procedures
- User-access and privilege-review records
- System configuration screenshots/exports
- Security logs and monitoring reports
- Vulnerability and patch reports
- Training and incident-response records

Common Findings

- Excessive or outdated user privileges
- Missing patches or insecure configurations
- Incomplete logging or log retention
- Policies not matching actual practice
- Weak evidence of periodic reviews
- Corrective actions not completed on time

Compliance Reporting

1. A compliance report communicates the scope, criteria, assessment results and outstanding risks.
2. Typical sections: executive summary, scope, methodology, control status, findings, evidence, risk/severity, corrective actions and owners.
3. Reports should distinguish compliant controls, partial compliance, exceptions and unresolved gaps.
4. Management reporting may use KPIs such as overdue patches, access-review completion, audit findings and remediation closure rates.
5. Evidence should be accurate, traceable, protected from unauthorized modification and retained according to policy.

Case Study & Recap

Scenario: An online healthcare service stores patient profiles, medical information and account credentials in a cloud environment.

1. Which compliance obligations could apply? What sensitive data is involved?
2. Identify at least five controls for access, encryption, logging, vulnerability management and incident response.
3. What evidence would an auditor request to verify these controls?

Key takeaway: compliance is not a one-time checklist; it requires governance, risk-based controls, evidence, assessment, remediation and continuous monitoring.